OCTOBER 2026

Governed agents: security, data and cloud

Integration, security, data and cloud foundations for agentic AI in regulated banking

Placida Fernando

THE IDEA

Agents are only as safe as the foundation beneath them

Integration

Agents reach systems only only through governed APIs, APIs, events and approved approved tools.

Security

Every agent has its own identity, least-privilege access access and a kill switch.

Data

Every conclusion traces back to governed source data.

Cloud

A platform that scales agents agents without losing control control of cost or resilience. resilience.

Public context: When a bank partner with Banking Core System like FIS and Anthropic Financial Crimes AI Agent, where investigators keep full decision authority and outputs must be traceable and auditable.

INTEGRATION

Agents are the newest consumer of your integration layer

Pattern	Role for agents	Standard to set
APIs	Lookups and actions that need an immediate answer	Contract first, OAuth2 scopes, gateway policies
Events and messaging	Alerts and state changes that trigger an agent	Schema and compatibility rules, dead-letter handling
MCP tools	The standard way for agents to call tools and data	A registry of vetted tools only
Legacy ESB and batch	Core and vendor systems still on SOA or files	Wrap behind APIs, retire over time

MCP is the Model Context Protocol, the open standard Anthropic introduced for connecting agents to tools and data.

INTEGRATION

Standards and an operating model that scale

Integration standards

Approved patterns, protocols and a security baseline, plus a clear rule for API, event or batch.

Tool selection

Judge platforms such as MuleSoft, RabbitMQ and Informatica against today’s footprint and tomorrow’s needs.

Ecosystem map

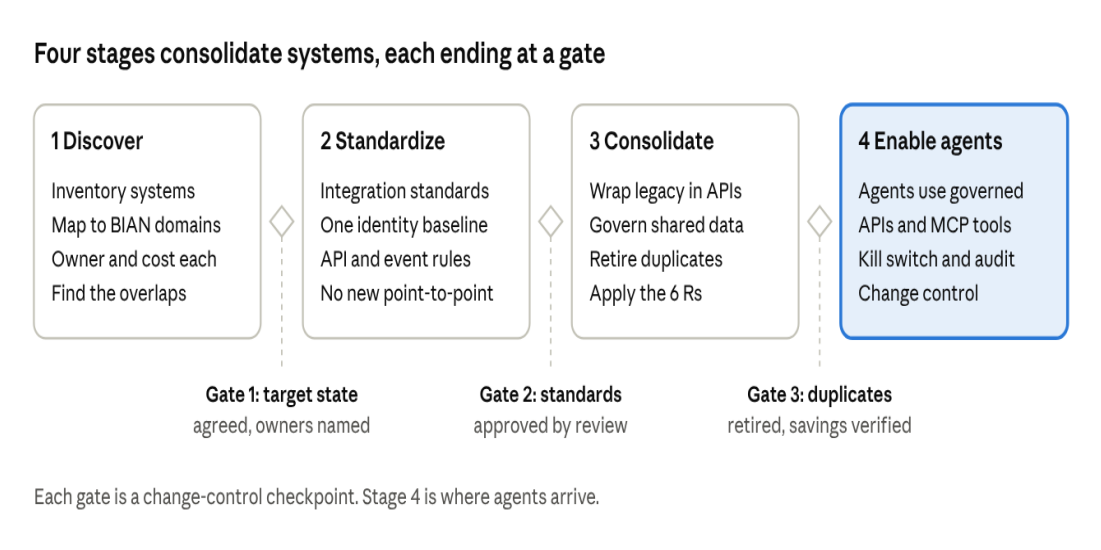
Living diagrams of every system, integration point and owner, using BIAN as a shared vocabulary.

Review and operations

A review gate for new integrations, monitoring, versioning and a and a path to retirement.

Tool names taken from the published role description. Standards are a proposal.

The roadmap: four stages to consolidate systems



Stage	What you do	What to say to the CTO
1 Discover	Inventory applications and integrations, map them to BIAN domains, name an owner and a cost for each	I'd start by learning what exists and who owns it.
2 Standardize	Integration standards, one identity and security baseline, rules for APIs and events, no new point-to-point links	Standards first, so we stop adding complexity.
3 Consolidate	Wrap legacy behind APIs, move shared data to a governed platform, retire duplicate systems using the 6 Rs	Consolidate in steps, with a gate at each one.
4 Enable agents	Agents use governed APIs and approved MCP tools, with a kill switch, an audit trail and change control	Agents then plug into a simpler, governed layer.

Bank on a page: BIAN

Reference Data

- **Party**
- External Agency
- Market Data
- Product Management

Sales & Service

- Channel Specific
- Cross Channel
- Marketing
- Sales
- **Customer Management**
- Servicing

Operations & Execution

Product-specific

- **Loans & Deposits**
- Investment Management
- **Cards**
- Wholesale Trading
- Market Operations
- Trade Banking
- Corporate Financing & Advisory Services
- **Consumer Services, including Trust Services**

Cross-product

- **Payments**
- **Account Management**
- Operational Services
- Collateral Administration

Risk & Compliance

- Bank Portfolio & Treasury
- Models
- Business Analysis
- **Regulations & Compliance**

Business Support

- IT Management
- Finance
- Non IT and HR Enterprise Services
- Human Resource Management
- Knowledge & IP Management
- Buildings, Equipment and Facilities
- Corporate Relations
- Business Command & Control
- Business Direction
- Document Mgmt & Archive

Simplified from BIAN. Gold and bold = domains an AML investigation agent would likely draw on (illustrative).

SECURITY

How agents prove who they are: federation and beyond

Layer	What we implement	What it gives
Federation	Agents authenticate through the bank’ s identity provider using OIDC or SAML trust , OAuth2 grants access (access token). OIDC adds identity (ID token).	One identity authority, no local passwords
Workload identity	A unique identity per agent, such as a managed identity, service principal or SPIFFE ID	No static secrets in code
Tokens	Short-lived OAuth2 tokens, scoped and audience-bound, with token exchange to act on behalf of a user	Least privilege, small blast radius
Transport	Mutual TLS between services, enforced by a service mesh	Both sides authenticated and encrypted
Authorization	Role and attribute policies checked at the gateway on every call	Permission and intent verified each time

Proposed identity pattern for deploying agents. Confirm against the bank’s identity platform.

SECURITY

Where attackers strike, and the control that answers

Threat	What it looks like	Control
Prompt injection	Input that breaks the agent's context	AI gateway: inspect inputs and outputs, block injections and data leaks
Poisoning	Tampered policies, preferences or the model itself	Trace and scan: immutable logs, plus network, endpoint and model scanning
Hijacked interfaces	Attacks on MCP calls, APIs, tools and data	Tool registry: only vetted APIs, data sources and tools, with mTLS between services
Stolen credentials	Copied or escalated to gain privilege	Vault: unique per agent, just in time, no static secrets

Also in place: a kill switch, throttles, canary releases and investigators who make the final call.

DATA GOVERNANCE

Governance built into each medallion layer

Bronze

Raw

- Land source data as is, immutable
- Classify and tag sensitive fields at ingest
- Lineage starts here

Silver

Cleansed and conformed

- Validate with data quality expectations
- Conform entities and master data
- Mask or tokenize PII for wider use

Gold

Curated for the business

- Business-ready tables for investigators and agents
- Agents read gold by default, silver by approved exception
- Row and column controls by purpose

Unity Catalog spans all three layers: one place for access, lineage, audit and tags.

Proposed governance pattern for a Databricks lakehouse

DATA GOVERNANCE

Controls that make every agent decision traceable

Control	On Databricks	Why it matters for agents
Classification	Tags on tables and columns for PII and sensitivity	Agents reach only data they are cleared for
Access by purpose	Row filters, column masks and attribute-based policies	Least privilege per agent, not per team
Agent identity	One service principal per agent, no shared accounts	Every action maps to one accountable identity
Lineage	Table and column lineage from bronze to gold	Each conclusion links back to its source records
Audit	Audit logs and system tables, retained for examiners	Examiners can reconstruct what the agent saw and did

Owners approve access, stewards run quality rules, and agent risk follows SR 11-7 model risk guidance.

CLOUD MIGRATION

One path per workload, not one path for all

Rehost

Lift and shift. Fastest, with minimal change.

Replatform

Lift, tinker and shift. Small optimizations.

Refactor

Re-imagine the application. Costly, often the most valuable.

Repurchase

Move to a different product, such as SaaS. SaaS.

Retire

Switch off what is no longer needed.

Retain

Keep it where it is, for now.

6Rs - Sequence by risk and data sensitivity, and set guardrails first: cost budgets with auto-shutdown, tested multi-zone recovery, bank-controlled keys and a documented exit plan.

The six migration strategies, commonly called the 6 Rs

The agent proves the model. The foundation makes it safe to repeat.

QUESTIONS

- How are agent identities and credentials managed in the pilot today?
- Where does the bank’s data governance end and the partners’ begin?
- Which systems feeding the agent are next in the cloud roadmap?